Table 5.5 Client code and server HTTP response when `withCredentials` is `true` but Access-Control-Allow-Credentials isn't set

Client code	Server HTTP response

`var xhr = new XMLHttpRequest();`
`xhr.open('GET',`
`  'http://127.0.0.1:9999/api/posts');`
`xhr.withCredentials = true;`
`xhr.send();`
	`HTTP/1.1 200 OK`
	`Access-Control-Allow-Origin:`
	`  http://localhost:1111`

As you can see, there is a lot of subtlety involved when setting the values for the `withCredentials` and Access-Control-Allow-Credentials. As a rule, it's best not to set these values unless you need the cookie on cross-origin requests. Requests without cookies are safer and easier to debug, because they don't contain any user-specific information.

This section took a comprehensive look at the `withCredentials` property and Access-Control-Allow-Credentials header. But there are still a few more caveats to be aware of when using these settings, which we'll cover next.

5.1.5 Caveats to cookie support

While the Access-Control-Allow-Credentials header allows cookies to be set on CORS requests, there are still a few caveats to how they are used.

COOKIES ON THE CLIENT

JavaScript's `document.cookie` property allows programmatic access to a site's cookies. Using `document.cookie`, JavaScript code can read and write the value of a cookie, as shown in the following code snippet. You can print the value of the cookie to the console using

```
console.log(document.cookie);
```

and you can set the cookie value using

```
document.cookie = 'newcookie=1';
```

But the preceding code will not work with cross-origin cookies. The `document.cookie` property can't read or write the value from another origin. Calling `document.cookie` from the client will return only the client's own cookies, not the cross-origin cookies.

This is because cookies themselves have a same-origin policy similar to the same-origin policy for HTTP requests. Each cookie has a path and a domain, and only pages from that path and domain can read the cookie. So while the cookie is included in the CORS request, the browser still honors the cookie's same-origin policy, and keeps the cookie hidden from client code.

COOKIES WHEN THERE IS NO PREFLIGHT REQUEST

Based on the previous discussion, you may think that if a server doesn't want cookies, all it needs to do is omit the Access-Control-Allow-Credentials header. However this isn't quite true. Cookies may still be sent to the server in the case where the request